

Identidad y gestión de accesos

IAM deja de ser una caja negra

Desde la primera sesión sabes que tu rol en el Learner Lab está preasignado, y que no puedes crear usuarios ni roles nuevos. Hoy no cambia esa regla.

Pero sí dejas de tratar IAM como una caja negra que «ya viene configurada» y empiezas a leerla, corregirla y usarla de verdad: aplicar un rol existente a una instancia sin credenciales, y detectar por qué una política está mal escrita antes de que cause un problema real.

Usuarios, roles, políticas y credenciales temporales

IAM tiene varias piezas que conviene distinguir bien — ya llevas semanas usando una de ellas sin nombrarla:

Pieza	Qué es	En el Learner Lab
Usuario	Identidad fija, con credenciales de larga duración	No puedes crear ninguno — no lo necesitas
Rol	Identidad que se «presta» temporalmente a quien la asume	Tienes uno preasignado (assumed-role)
Política	Documento que dice qué acciones están permitidas o denegadas	Puedes leerlas y corregirlas — no crear roles nuevos
Credenciales temporales	Claves con caducidad, generadas al asumir un rol	Es lo que usa tu sesión ahora mismo

De dónde sale la credencial de una instancia

Toda llamada a la API de AWS va firmada con una credencial. Si una instancia necesitara las claves fijas de un usuario, esas claves tendrían que vivir guardadas dentro de ella — el mismo problema de «credenciales en el código» que ya evitaste en el Tema 3 con Secrets Manager.

Un rol asignado a la instancia lo evita de raíz: AWS publica credenciales temporales —caducan y se renuevan solas— en el servicio de metadatos de la instancia (169.254.169.254). El SDK ya sabe mirar ahí por defecto: tu código nunca necesita pedir las.

Por qué S3Storage no tiene ninguna clave de acceso

```
S3Client.builder().build()  
// sin pasarle ninguna credencial
```

El SDK, al no recibir ninguna clave explícita, pregunta al servicio de metadatos qué credenciales tiene la instancia ahora mismo, y las usa. Si esa instancia se termina y otra la sustituye, la nueva pregunta lo mismo y recibe las suyas — nadie ha copiado ni rotado nada a mano.

Anatomía de una política

```
{
  "Effect": "Allow",
  "Action": ["s3:GetObject", "s3:PutObject"],
  "Resource": "arn:aws:s3:::escaparate-imagenes-<id>/*",
  "Condition": {
    "Bool": { "aws:SecureTransport": "true" }
  }
}
```

Campo	Responde a	En el ejemplo
Effect	¿Permite o deniega?	Allow
Action	¿Qué operación?	Leer y escribir un objeto
Resource	¿Sobre qué recurso?	Objetos del bucket de imágenes
Condition	¿Bajo qué circunstancia?	Solo si la conexión va cifrada

Leer una política, frase por frase

«Permite leer y escribir objetos dentro del bucket de imágenes de Escaparate, pero solo si la conexión va cifrada.» Cuatro campos, una frase — cuando te enfrentes a la política real de tu rol en la Actividad 5.2, sigue leyéndola exactamente así, campo a campo.

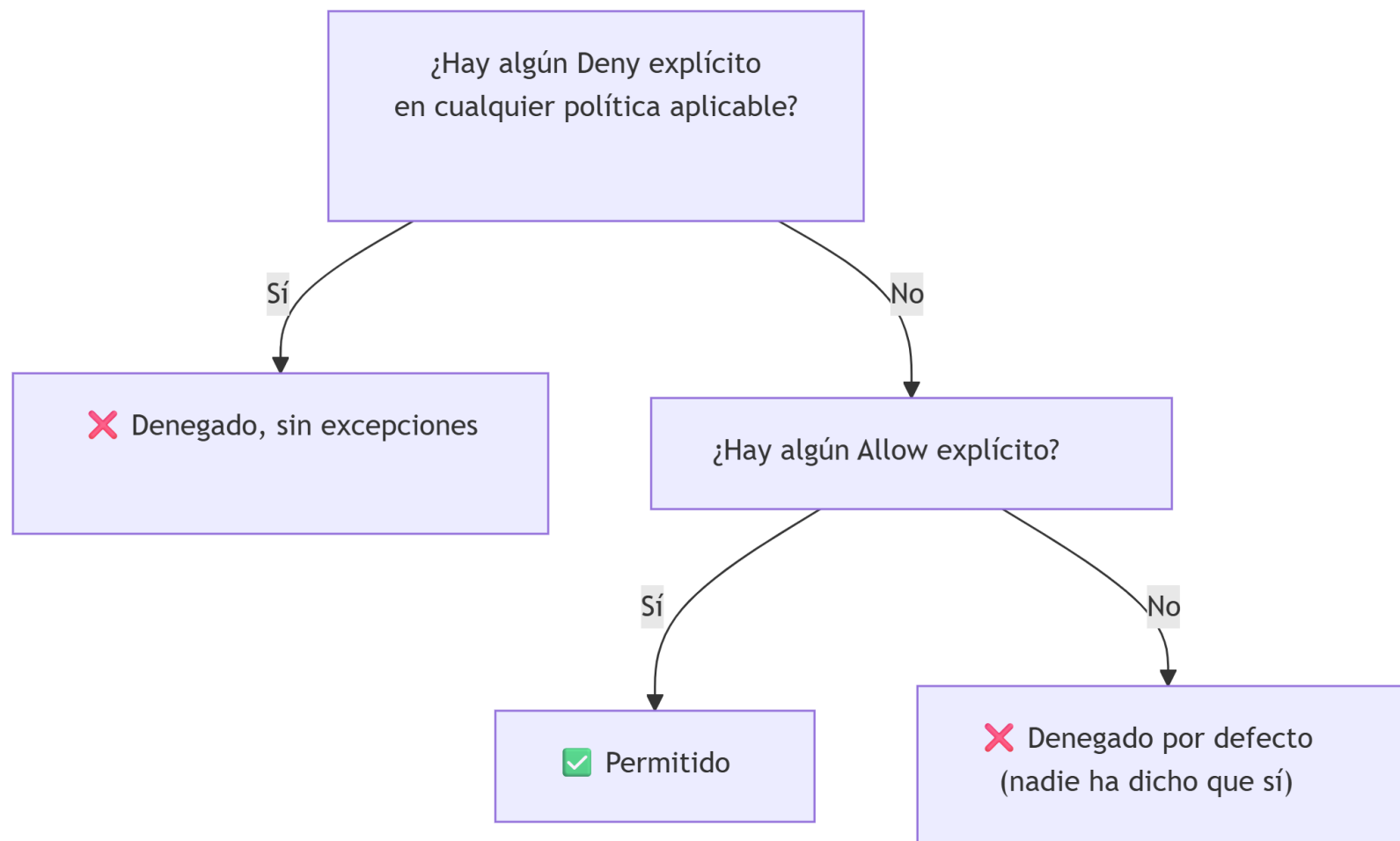
El simulador de políticas de IAM

Leer una política te dice qué debería permitir sobre el papel, pero con varias líneas y comodines de por medio es fácil equivocarse. El simulador te deja elegir una política, una acción y un recurso, y responde directamente «permitido» o «denegado» — sin ejecutar nada de verdad contra tu cuenta.

Con la política del ejemplo: s3:GetObject sobre un objeto del bucket → Permitido. s3:DeleteObject sobre ese mismo objeto → Denegado, porque la política nunca menciona esa acción. Vas a hacer esta comprobación con la política real de tu rol en la Actividad 5.2.

Cómo se evalúa una política: quién gana

Casi nunca hay una sola política de por medio. El resultado no se decide sumando políticas: se decide con un orden fijo, siempre el mismo.



Principio de mínimo privilegio

Una identidad debe tener exactamente los permisos que necesita para su trabajo, ni uno más. No es una recomendación abstracta — tiene un coste medible cuando se ignora:

 Permisos amplios
«por si acaso»



 Cualquier fallo o filtración
tiene alcance mucho mayor

 Mínimo privilegio



 Un fallo queda contenido
al alcance estrictamente necesario

Un comodín de más es el error más común

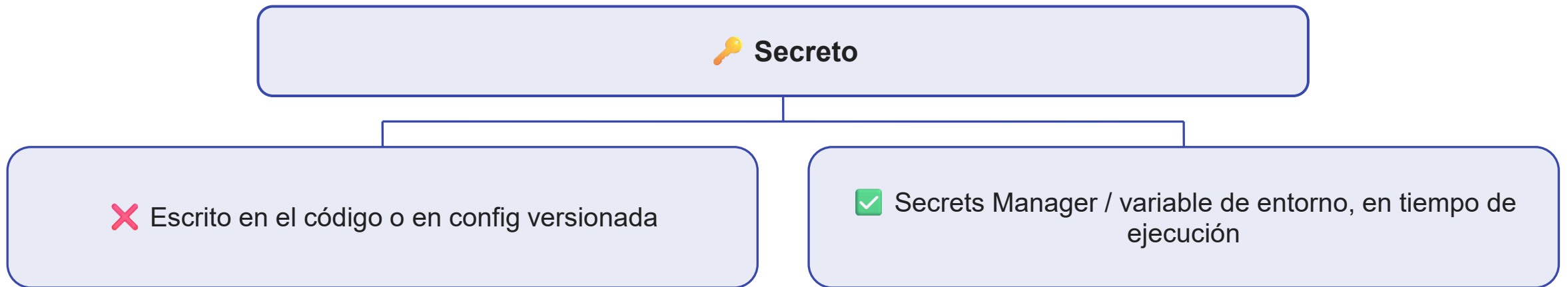
"Action": "s3:*" en vez de "s3:GetObject" da permiso para borrar y sobrescribir todo el almacenamiento. Vas a encontrarte este error en las políticas que corrijas en la Actividad 5.2.

MFA: una segunda prueba de identidad

El MFA (Multi-Factor Authentication) añade una segunda prueba de identidad —un código temporal, además de la contraseña— para las operaciones más sensibles. En el Learner Lab no lo configuras tú (la identidad ya viene resuelta por el rol asumido), pero en una cuenta real es la pieza que protege contra que una contraseña filtrada sea suficiente para entrar.

Gestión de secretos: nunca en el código

Ya aplicaste esta regla en el Tema 3 con la contraseña de la base de datos — hoy se generaliza a cualquier secreto: claves de API, tokens, certificados privados.



Un secreto filtrado sigue expuesto aunque lo borres

El historial de Git no olvida

El historial conserva versiones anteriores de cualquier fichero — borrar un secreto en el commit siguiente no lo elimina del historial. La única solución correcta ante un secreto filtrado es rotarlo (generar uno nuevo e invalidar el antiguo), nunca solo «quitarlo» del código.

Registro de auditoría

El registro de auditoría (CloudTrail) guarda un histórico de quién ha hecho qué, cuándo y desde dónde — cada llamada a la API queda registrada. Ya lo mencionaste como una de las cinco señales de la sesión pasada; hoy lo usas para responder a «¿quién ha tocado esto, y cuándo?»

Si en la incidencia de la sesión pasada un grupo de seguridad tenía una regla que no debería estar ahí: las métricas y los registros te dijeron qué estaba fallando; el registro de auditoría te dice quién cambió esa regla y cuándo.

Ideas clave

- Un rol se presta temporalmente (credenciales que caducan); un usuario tiene credenciales fijas — el Learner Lab usa un rol preasignado.
- Una política se lee en cuatro campos: efecto, acción, recurso y condición.
- Cuando hay varias políticas en juego: un Deny explícito gana siempre; si no, un Allow explícito permite; si ninguna dice nada, deniega por defecto.
- El principio de mínimo privilegio limita el alcance de cualquier fallo — un comodín de más es el error más común que lo rompe.
- Ningún secreto va nunca en texto plano en un fichero versionado — si uno llega a estarlo, la solución es rotarlo, no borrarlo.
- El registro de auditoría responde a quién ha hecho qué y cuándo — completa el diagnóstico más allá de métricas y registros.